



พื้นฐาน PHP สำหรับ Web Application

Asst.Prof. Monlica Wattana, Ph.D

Department of Computer Science, Khon Kaen University

CP423324 Database and Web Security





Outline



- การทำงานของ PHP บน Web Application
- พื้นฐานภาษา PHP
- การจัดการ Input อย่างปลอดภัยด้วย PHP





การทำงานของ PHP บน Web Application



HOW PHP WORKS

PHP runs on the server, not directly in the browser. The server executes PHP and sends the result back to the browser.

CLIENT SIDE (User's Browser)

1 Web Browser (Chrome, Firefox, Safari, etc.)

✗ Does not execute PHP directly



6 Browser displays the result

Hello from PHP!



1 Request a .php page

SERVER SIDE (Web Server)

2 Server receives the request



Web Server + PHP Interpreter

3 PHP code is executed on the server

```
<?php
echo "Hello from PHP!";
?>
```



4 Server generates output

HTML or JSON
(HTML / CSS / JavaScript or JSON)

5 Response sent back
(HTML / CSS / JavaScript or JSON)





การทำงานของ PHP บน Web Application



ขั้นตอนการทำงาน

1. Browser ส่ง Request เพื่อเรียกหน้าเว็บ .php
2. Web Server รับ Request และส่งต่อให้ PHP Interpreter
3. PHP Code ถูกประมวลผลบน Server
4. Server สร้างผลลัพธ์ เช่น HTML หรือ JSON
5. Server ส่ง Response กลับไปยัง Browser
6. Browser แสดงผลลัพธ์ ให้ผู้ใช้เห็นเป็นหน้าเว็บ





พื้นฐานภาษา PHP



- การเขียนคำสั่ง PHP จะเขียนโค้ด PHP แทรกใน ภาษา HTML โดยใช้ แท็ก `<?php ... ?>`
- ต้องมี ; ลงท้ายคำสั่ง
- การกำหนดตัวแปร: กฎการตั้งชื่อตัวแปร
 - ขึ้นต้นด้วย \$
 - ตามด้วย A-Z หรือ a-z หรือ _
 - ตามด้วย A-Z หรือ a-z หรือ 0-9 หรือ _ เช่น \$myvar; \$my_var; \$myVar;
 - Case Sensitive ตัวพิมพ์ใหญ่/เล็กถือเป็นคนละตัว เช่น \$myvar; \$Myvar; \$MyVar; \$myVar;
 - ไม่ตั้งชื่อซ้ำคำสั่งงาน เช่น \$_POST; \$_SESSION; \$_GET;





พื้นฐานภาษา PHP



- ชนิดของตัวแปร

- Boolean : True , False ตัวอย่าง

```
$isLoggedIn = true;  
if ($isLoggedIn) {  
    echo "Welcome!" }  
}
```

- Integer : เลขจำนวนเต็ม ตัวอย่าง

```
$count = 42;  
echo $count * 2;    // result 84
```

- Float หรือ double : เลขจำนวนจริง

ตัวอย่าง

```
$price = 199.95;  
$tax   = 0.07;  
echo $price * (1 + $tax);    // result 213.9465
```





พื้นฐานภาษา PHP



- ชนิดของตัวแปร
 - String : ตัวอักษรที่นำไปคำนวณทางคณิตศาสตร์ไม่ได้

ตัวอย่าง

```
$firstName = "Alice";  
$lastName  = "Wonderland";  
echo "Hello". $firstName . " " . $lastName;
```

- Array : ตัวแปรชุด

ตัวอย่าง

```
// Indexed array  
$colors = ["Red", "Green", "Blue"];  
echo $colors[1]; // result Green
```

```
// Associative array  
$student = [  
    "id"      => "670100000-1",  
    "name"    => "Alice",  
    "major"   => "Cyber"  
];  
echo $student["name"]; // result Alice
```





พื้นฐานภาษา PHP



- ชนิดของตัวแปร
 - Object : เก็บ instance ของคลาสในเชิง OOP โดยมีคุณสมบัติ (properties) และพฤติกรรม (methods)

ตัวอย่าง

```
class Car {  
    public $make;  
    public function honk() {  
        echo "beep!";  
    }  
}  
  
$myCar = new Car();  
$myCar->make = "Toyota";  
echo $myCar->make;    // result Toyota  
$myCar->honk();        // result beep!
```





พื้นฐานภาษา PHP



- ชนิดของตัวแปร

- Resource : สำหรับอ้างอิงถึงแหล่งภายนอก เช่น การเปิดไฟล์ข้อมูล การเชื่อมต่อฐานข้อมูล ต้องใช้ฟังก์ชันเฉพาะเพื่อเปิด-ปิด (เช่น fopen()/fclose())

ตัวอย่าง

```
$fp = fopen("data.txt", "r"); // $fp stores a file resource
// read data
fclose($fp);
```

- Null : ตัวแปรที่ไม่มีค่า เรียกว่ามีค่าเป็น Null เช่น เมื่อประกาศตัวแปรแล้วแต่ยังไม่ได้กำหนดค่าใดๆให้ตัวแปร กำหนดค่าให้ตัวแปรมีค่าเป็น Null;

ตัวอย่าง

```
$x = null;
if (is_null($x)) {
    echo "\$x is Null.";
}
```





พื้นฐานภาษา PHP



- Constant คือค่าคงที่ที่ไม่ควรเปลี่ยนระหว่างการทำงาน
- ใช้ define() หรือ const

```
<?php  
define("APP_NAME", "Lab03 PHP App");  
const VERSION = "1.0";  
?>
```

- Magic Constants เช่น __FILE__, __DIR__, __LINE__ ช่วยบอกข้อมูลตำแหน่งไฟล์/บรรทัด

```
<?php  
echo APP_NAME;  
echo __FILE__;  
echo __DIR__;  
?>
```





พื้นฐานภาษา PHP



- Numbers, Casting และ Math
 - Numbers: `$price = 199.50;`
 - Casting: `$qty = (int) $_POST["qty"];`
 - Math: `$total = $price * $qty;`
 - ฟังก์ชัน Math: `round()`, `min()`, `max()`, `abs()`

```
<?php
$price = 199.50;
$qty = (int) $_POST["qty"];
$total = $price * $qty;
echo round($total, 2);
?>
```





พื้นฐานภาษา PHP



- Operators

- คำนวณตัวเลข : +, -, *, /, %
- กำหนดค่า: =, +=, -=
- เปรียบเทียบ: ==, ===, !=, >, <, >=, <=
- รวมเงื่อนไข: &&, ||, !
- ต่อข้อความ : . (จุด)

```
if ($email == "") { echo "Email is required"; }  
if ($age >= 18 && $age <= 60) { echo "OK"; }  
echo "Name: " . $fullname;
```





พื้นฐานภาษา PHP



- If...Else...Elseif ใช้ตรวจสอบเงื่อนไข เช่น ค่าว่าง หรือค่าที่ไม่ถูกต้อง
 - if: ตรวจสอบเงื่อนไขแรก
 - elseif: ตรวจสอบเงื่อนไขถัดไป
 - else: ทำเมื่อไม่เข้าเงื่อนไขใดเลย

```
<?php
    if ($fullname == "") {
        echo "Full name is required";
    } elseif (strlen($fullname) > 50) {
        echo "Full name is too long";
    } else {
        echo "Valid full name";
    }
?>
```





พื้นฐานภาษา PHP



- Switch และ Match ใช้เลือกการทำงานตามค่าที่รับมา

```
switch ($category) {  
    case "php":  
        echo "PHP";  
        break;  
    case "html":  
        echo "HTML";  
        break;  
    default:  
        echo "Unknown";  
}
```

```
$category_label = match($category)  
{  
    "php" => "PHP",  
    "html" => "HTML",  
    default => "Unknown"  
};  
  
echo $category_label;
```





พื้นฐานภาษา PHP



- Loops
 - for ทำซ้ำตามจำนวนรอบที่รู้แน่นอน
 - while ทำซ้ำตราบเท่าที่เงื่อนไขเป็นจริง
 - foreach วนข้อมูลใน Array เช่น รายการ error

```
<?php
    $errors = ["Email is required", "Invalid
    phone"];

    foreach ($errors as $error) {
        echo "<li>" . $error . "</li>";
    }
?>
```





พื้นฐานภาษา PHP



- Function ใช้รวมคำสั่งที่ต้องใช้ซ้ำ และช่วยให้โค้ดอ่านง่ายขึ้น
 - ตั้งชื่อ function ให้สื่อความหมาย
 - รับค่าเข้าผ่าน parameter
 - คืนค่าด้วย return
 - ใช้ซ้ำได้ในหลายไฟล์ผ่าน require_once

```
<?php
    function isEmptyValue($value) {
        return trim($value) == "";
    }
?>
```

ส่งผลลัพธ์กลับเป็น true หรือ false





พื้นฐานภาษา PHP



- RegEx และ RegEx Functions
 - Regular Expression ใช้ตรวจสอบรูปแบบข้อมูล
 - preg_match() ใช้ตรวจสอบว่าข้อมูลตรง pattern หรือไม่
 - เหมาะกับเบอร์โทร รหัสนักศึกษา หรือรูปแบบเฉพาะ

```
<?php
    $phone = "0899999999";

    if (preg_match("/^[0-9]{10}$/", $phone)) {
        echo "Valid phone";
    } else {
        echo "Invalid phone";
    }
?>
```



HTML pattern ตรวจสอบที่ Browser แต่ preg_match() ตรวจสอบที่ Server





พื้นฐานภาษา PHP

- คำสั่ง include, require, include_once, require_once ใช้สำหรับ เรียกใช้ไฟล์ PHP ภายนอก เข้ามาในไฟล์ปัจจุบัน เช่น config.php, header.php, footer.php หรือไฟล์ฟังก์ชัน

คำสั่ง	ลักษณะการทำงาน
include	เรียกไฟล์เข้ามาใช้งาน หากไม่พบไฟล์จะแสดง Warning และโปรแกรมยังทำงานต่อ
require	เรียกไฟล์ที่จำเป็นต่อระบบ หากไม่พบไฟล์จะเกิด Error และหยุดการทำงาน
include_once	เหมือน include แต่เรียกไฟล์เดิมเพียงครั้งเดียว
require_once	เหมือน require แต่เรียกไฟล์เดิมเพียงครั้งเดียว

ตัวอย่าง:

```
require_once "config.php";
```





พื้นฐานภาษา PHP



การรับค่าจากฟอร์ม ทำได้โดยใช้ตัวแปรพิเศษ 3 แบบ ได้แก่

1. \$_GET:

- ใช้สำหรับรับค่าที่ส่งมากับ URL (query string)
- ค่าที่ส่งมาจะปรากฏใน URL
- มีข้อจำกัดเรื่องจำนวนและขนาดของข้อมูลที่สามารถส่งได้

2. \$_POST:

- ใช้สำหรับรับค่าที่ส่งมาจากฟอร์ม (โดยทั่วไป)
- ค่าที่ส่งมาจะไม่ปรากฏใน URL
- นิยมใช้สำหรับการส่งข้อมูลที่ไม่ต้องการให้ปรากฏใน Address Bar





พื้นฐานภาษา PHP



3. \$_REQUEST:

- เป็นตัวแปรที่รวมค่าจากทั้ง \$_GET และ \$_POST
- สามารถรับค่าได้ทั้งจาก URL และฟอร์ม
- มีความยืดหยุ่นสูงในการใช้งาน

ตัวแปรพิเศษ \$_SERVER['REQUEST_METHOD'] คือ ตัวแปรที่ใช้ตรวจสอบว่า Request ที่ส่งมายังไฟล์ PHP นั้นใช้วิธีการส่งข้อมูลแบบใด เช่น GET หรือ POST





การจัดการ Input อย่างปลอดภัยด้วย PHP



1. trim() ใช้ตัดช่องว่างหัวท้าย

```
<?php
$fullname = trim($_POST["fullname"] ?? "");
$email = trim($_POST["email"] ?? "");
?>
```

2. empty() ใช้ตรวจว่าค่าเป็นค่าว่างหรือไม่

```
<?php
if (empty($fullname) || empty($email)) {
    echo "Please fill in all required fields.";
}
?>
```





การจัดการ Input อย่างปลอดภัยด้วย PHP



3. htmlspecialchars() ใช้แปลงตัวอักษรพิเศษเป็น HTML entities (เพื่อไม่ให้ browser ตีความเป็น script)

```
$name = htmlspecialchars($_POST['name']);
```

4. htmlentities() คล้ายกับ htmlspecialchars() แต่แปลงอักขระได้ครอบคลุมมากกว่า

```
$comment = htmlentities($_POST['comment'], ENT_QUOTES, 'UTF-8');
```

5. strip_tags() ใช้ลบแท็ก HTML ทั้งหมด

```
$message = strip_tags($_POST['message']);
```



การจัดการ Input อย่างปลอดภัยด้วย PHP

6. filter_var() – ตรวจสอบและกรอง input ตามประเภท

```
$email = filter_var($_POST['email'], FILTER_VALIDATE_EMAIL);  
$age = filter_var($_POST['age'], FILTER_VALIDATE_INT);
```

7. filter_input() – กรองข้อมูลจาก \$_GET, \$_POST, \$_COOKIE โดยตรง

```
$email = filter_input(INPUT_POST, 'email', FILTER_VALIDATE_EMAIL);
```

input type

- INPUT_GET
- INPUT_POST
- INPUT_COOKIE
- INPUT_SERVER
- INPUT_ENV



ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP

Student Registration

Full Name

Alice Green

Email

alice@kku.ac.th

Student ID

673330000-1

Phone

0899999999

Activity Type

Web Security

Note

HTML, PHP

Register

Reset

Registration Result

Request Method: **GET**

Registration data has been received successfully.

Full Name	Alice Green
Email	alice@kku.ac.th
Student ID	673330000-1
Phone	0899999999
Activity Type	Web Security
Note	HTML, PHP

Back to Form



ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



- โครงสร้างไฟล์

การแยกแบบนี้ เพื่อความรับผิดชอบของแต่ละไฟล์ ทำให้โค้ดอ่านง่ายและดูแลต่อได้

- index.php แสดงหน้า Form
- process.php รับค่าและประมวลผล
- config.php เก็บค่ากลาง/ฟังก์ชัน

Lec03/

- └─ index.php
- └─ process.php
- └─ config.php





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ไฟล์ config.php

```
<?php
    $app_name = "Student Registration";
    /*
        h() ใช้สำหรับแสดงผลข้อมูลจากผู้ใช้อย่างปลอดภัย
        โดยแปลงอักขระพิเศษไม่ให้ Browser ตีความเป็น HTML หรือ Script
    */
    function h($value) {
        return htmlspecialchars($value, ENT_QUOTES, "UTF-8");
    }
    /*
        isEmptyValue() ใช้ตรวจสอบว่าค่าที่รับมาเป็นค่าว่างหรือไม่
        โดยตัดช่องว่างด้านหน้าและด้านหลังออกก่อนตรวจสอบ
    */
    function isEmptyValue($value) {
        return trim($value) == "";
    }
}
```

?>





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ไฟล์ Index.php

```
<?php
require_once "config.php";
?>

<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <title><?php echo h($app_name); ?></title>

    <style>
        body {
            font-family: Arial, sans-serif;
            background-color: #eef7f3;
            margin: 0;
            padding: 0;
        }
```

The screenshot shows a web form titled "Student Registration". It contains several input fields: "Full Name" with placeholder text "Enter your full name", "Email" with placeholder text "example@kkumail.com", "Student ID" with placeholder text "673380000-1", and "Phone" with placeholder text "0899999999". There is a dropdown menu for "Activity Type" with the text "-- Select Activity Type --". Below these is a "Note" section with a text area and placeholder text "Enter additional note". At the bottom of the form are two buttons: "Register" (green) and "Reset" (grey).

```
.container {
    width: 650px;
    margin: 40px auto;
    background-color: #ffffff;
    padding: 25px;
    border-radius: 10px;
    border: 1px solid #b7d8cc;
}

h1 {
    color: #006b4f;
    margin-bottom: 5px;
}

label {
    display: block;
    margin-top: 15px;
    font-weight: bold;
}
```





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ไฟล์ Index.php(ต่อ)

```
input,
select,
textarea {
    width: 100%;
    padding: 8px;
    margin-top: 5px;
    box-sizing: border-box;
    border: 1px solid #9fcfc0;
    border-radius: 5px;
    font-size: 15px;
}
textarea {
    height: 90px;
}
.button-group {
    margin-top: 20px;
}
button {
    padding: 10px 20px;
    border: none;
    border-radius: 5px;
    cursor: pointer;
    font-size: 15px;
}
```

```
.submit-btn {
    background-color: #008060;
    color: white;
}

.reset-btn {
    background-color: #cccccc;
    color: #333333;
}

.note {
    background-color: #f2fbf7;
    border-left: 5px solid #008060;
    padding: 10px;
    margin-top: 15px;
    color: #333333;
}
</style>
</head>
```





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ไฟล์ Index.php(ต่อ)

```
<body>
<div class="container">
  <h1><?php echo h($app_name); ?></h1>
  <form action="process.php" method="get">

    <label for="fullname">Full Name</label>
    <input type="text" id="fullname" name="fullname"
      maxlength="50" placeholder="Enter your full name"
      required>

    <label for="email">Email</label>
    <input type="email" id="email" name="email"
      placeholder="example@kkumail.com">

    <label for="student_id">Student ID</label>
    <input type="text" id="student_id" name="student_id"
      placeholder="673380000-1">

    <label for="phone">Phone</label>
    <input type="tel" id="phone" name="phone"
      placeholder="0899999999">
```

Student Registration

Full Name

Email

Student ID

Phone

Activity Type

Note



ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ไฟล์ Index.php(ต่อ)

```
<label for="activity_type">Activity Type</label>
<select id="activity_type" name="activity_type">
  <option value="">-- Select Activity Type --</option>
  <option value="web_security">Web Security</option>
  <option value="database_security">Database Security</option>
  <option value="secure_coding">Secure Coding</option>
</select>

<label for="note">Note</label>
<textarea id="note" name="note" maxlength="200"
  placeholder="Enter additional note"></textarea>

<div class="button-group">
  <button type="submit" class="submit-btn">Register</button>
  <button type="reset" class="reset-btn">Reset</button>
</div>

</form>
</div>
</body>
</html>
```

Student Registration

Full Name

Email

Student ID

Phone

Activity Type

-- Select Activity Type --

Note

Enter additional note

Register

Reset





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ไฟล์ process.php

```
<?php
require_once "config.php";

$errors = [];

$request_method = $_SERVER["REQUEST_METHOD"];

if ($request_method == "GET") {
    $fullname = trim($_GET["fullname"] ?? "");
    $email = trim($_GET["email"] ?? "");
    $student_id = trim($_GET["student_id"] ?? "");
    $phone = trim($_GET["phone"] ?? "");
    $activity_type = trim($_GET["activity_type"] ?? "");
    $note = trim($_GET["note"] ?? "");
} elseif ($request_method == "POST") {
    $fullname = trim($_POST["fullname"] ?? "");
    $email = trim($_POST["email"] ?? "");
    $student_id = trim($_POST["student_id"] ?? "");
    $phone = trim($_POST["phone"] ?? "");
    $activity_type = trim($_POST["activity_type"] ?? "");
    $note = trim($_POST["note"] ?? "");
} else {
    $errors[] = "Invalid request method.";
}
```



Registration Result

Request Method: **GET**

Registration data has been received successfully.

Full Name	Alice Green
Email	alice@kku.ac.th
Student ID	673330000-1
Phone	0899999999
Activity Type	Web Security
Note	HTML, PHP

[Back to Form](#)





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ไฟล์ process.php(ต่อ)

```
/* ตรวจสอบค่าว่าง */
if (isEmptyValue($fullname)) {
    $errors[] = "Full Name is required.";
} elseif (strlen($fullname) > 50) {
    $errors[] = "Full Name must not exceed 50 characters.";
}

if (isEmptyValue($email)) {
    $errors[] = "Email is required.";
} elseif (!filter_var($email, FILTER_VALIDATE_EMAIL)) {
    $errors[] = "Invalid email format.";
}

if (isEmptyValue($student_id)) {
    $errors[] = "Student ID is required.";
} elseif (!preg_match("/^[0-9]{9}-[0-9]$/", $student_id)) {
    $errors[] = "Student ID format is invalid. Example: 673380000-1";
}

if (isEmptyValue($phone)) {
    $errors[] = "Phone is required.";
} elseif (!preg_match("/^[0-9]{10}$/", $phone)) {
    $errors[] = "Phone must contain exactly 10 digits.";
}
```

Registration Result

Request Method: **GET**

Please correct the following errors:

- Full Name is required.
- Email is required.
- Student ID is required.
- Phone is required.
- Activity Type is required.

[Back to Form](#)





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ไฟล์ process.php (ต่อ)

```
$allowed_activity_types = [
    "web_security",
    "database_security",
    "secure_coding"
];
if (isEmptyValue($activity_type)) {
    $errors[] = "Activity Type is required.";
} elseif (!in_array($activity_type, $allowed_activity_types)) {
    $errors[] = "Invalid Activity Type.";
}
if (strlen($note) > 200) {
    $errors[] = "Note must not exceed 200 characters.";
}
function getActivityLabel($activity_type) {
    return match ($activity_type) {
        "web_security" => "Web Security",
        "database_security" => "Database Security",
        "secure_coding" => "Secure Coding",
        default => "Unknown"
    };
}
?>
```

Registration Result

Request Method: **GET**

Registration data has been received successfully.

Full Name	Alice Green
Email	alice@kku.ac.th
Student ID	673330000-1
Phone	0899999999
Activity Type	Web Security
Note	HTML, PHP

[Back to Form](#)





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ไฟล์ process.php (ต่อ)

```
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <title>Registration Result</title>
  <style>
    body {
      font-family: Arial, sans-serif;
      background-color: #eef7f3;
      margin: 0;
      padding: 0;
    }
    .container {
      width: 650px;
      margin: 40px auto;
      background-color: #ffffff;
      padding: 25px;
      border-radius: 10px;
      border: 1px solid #b7d8cc;
    }
    h1 {
      color: #006b4f;
    }
```

Registration Result

Request Method: **GET**

Registration data has been received successfully.

Full Name	Alice Green
Email	alice@kku.ac.th
Student ID	673330000-1
Phone	0899999999
Activity Type	Web Security
Note	HTML, PHP

[Back to Form](#)





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ไฟล์ process.php (ต่อ)

```
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <title>Registration Result</title>
  <style>
    body {
      font-family: Arial, sans-serif;
      background-color: #eef7f3;
      margin: 0;
      padding: 0;
    }
    .container {
      width: 650px;
      margin: 40px auto;
      background-color: #ffffff;
      padding: 25px;
      border-radius: 10px;
      border: 1px solid #b7d8cc;
    }
    h1 {
      color: #006b4f;
    }
```

```
.method {
  background-color: #e8f5ff;
  border-left: 5px solid #007acc;
  padding: 10px;
  margin-bottom: 20px;
}

.error-box {
  background-color: #ffecec;
  border-left: 5px solid #d93025;
  padding: 15px;
  margin-bottom: 20px;
}

.success-box {
  background-color: #effaf3;
  border-left: 5px solid #008060;
  padding: 15px;
  margin-bottom: 20px;
}

ul {
  margin-top: 5px;
}
```





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ไฟล์ process.php (ต่อ)

```
table {  
    width: 100%;  
    border-collapse: collapse;  
    margin-top: 15px;  
}  
  
th,  
td {  
    border: 1px solid #b7d8cc;  
    padding: 10px;  
    text-align: left;  
}  
  
th {  
    background-color: #d9f1e8;  
    width: 35%;  
}
```

```
.back-link {  
    display: inline-block;  
    margin-top: 20px;  
    background-color: #008060;  
    color: white;  
    padding: 10px 15px;  
    text-decoration: none;  
    border-radius: 5px;  
}  
</style>  
</head>
```

Registration Result

Request Method: **GET**

Registration data has been received successfully.

Full Name	Alice Green
Email	alice@kku.ac.th
Student ID	673330000-1
Phone	0899999999
Activity Type	Web Security
Note	HTML, PHP

[Back to Form](#)





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ไฟล์ process.php(ต่อ)

```
<body>
<div class="container">
  <h1>Registration Result</h1>
  <div class="method">
    Request Method: <strong><?php echo h($request_method); ?></strong>
  </div>
  <?php if (!empty($errors)) { ?>
    <div class="error-box">
      <strong>Please correct the following errors:</strong>
      <ul>
        <?php foreach ($errors as $error) { ?>
          <li><?php echo h($error); ?></li>
        <?php } ?>
      </ul>
    </div>
  <?php } else { ?>
    <div class="success-box">
      Registration data has been received successfully.
    </div>
```





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ไฟล์ process.php(ต่อ)

Registration Result

Request Method: **GET**

Registration data has been received successfully.

Full Name	Alice Green
Email	alice@kku.ac.th
Student ID	673330000-1
Phone	0899999999
Activity Type	Web Security
Note	HTML, PHP

[Back to Form](#)

```
<table>
```

```
<tr>
    <th>Full Name</th>
    <td><?php echo h($fullname); ?></td>
</tr>
<tr>
    <th>Email</th>
    <td><?php echo h($email); ?></td>
</tr>
<tr>
    <th>Student ID</th>
    <td><?php echo h($student_id); ?></td>
</tr>
<tr>
    <th>Phone</th>
    <td><?php echo h($phone); ?></td>
</tr>
<tr>
    <th>Activity Type</th>
    <td><?php echo h(getActivityLabel($activity_type)); ?></td>
</tr>
<tr>
    <th>Note</th>
    <td>
        <?php
        if (isEmptyValue($note)) {
            echo "-";
        } else {
            echo h($note);
        }
        ?>
    </td> </tr> </table>
```





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ไฟล์ process.php(ต่อ)

Registration Result

Request Method: **GET**

Registration data has been received successfully.

Full Name	Alice Green
Email	alice@kku.ac.th
Student ID	673330000-1
Phone	0899999999
Activity Type	Web Security
Note	HTML, PHP

Back to Form

```
<?php } ?>
```

```
<a href="index.php" class="back-link">Back to Form</a>
```

```
</div>
```

```
</body>
```

```
</html>
```





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



Student Registration

Full Name

Email

Student ID

Phone

Activity Type

Note

Network tab showing the request to process.php?fullname=Alice+...

Name	Headers	Payload	Preview	Response
process.php?fullname=Alice+...				
js.js				
dom.js				
js.js				
dom.js				
js.js				
dom.js				
js.js				

Query String Parameters

Parameter	Value
fullname	Alice Green
email	alice@kku.ac.th
student_id	673330000-1
phone	0899999999
activity_type	web_security
note	HTML, PHP



http://localhost:8080/Lec03/process.php?fullname=Alice+Green&email=alice%40kku.ac.th&student_id=673330000-1&phone=0899999999&activity_type=web_security¬e=HTML%2C+PHP





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ผู้ไม่หวังดี: คัดลอก URL แล้วนำไปแก้ไขข้อมูล

`http://localhost:8080/Lec03/process.php?fullname=Bob+Green&email=alice%40kku.ac.th&student_id=673330000-1&phone=0899999999&activity_type=web_security¬e=HTML%2C+PHP`

Registration Result

Request Method: **GET**

Registration data has been received successfully.

Full Name	Bob Green
Email	alice@kku.ac.th
Student ID	673330000-1
Phone	0899999999
Activity Type	Web Security
Note	HTML, PHP

[Back to Form](#)

The screenshot shows the 'Network' tab of a browser's developer tools. A request to 'process.php?fullna...' is selected. The 'Payload' sub-tab is active, displaying the 'Query String Parameters'. The parameters listed are: fullname (Bob Green), email (alice@kku.ac.th), student_id (673330000-1), phone (0899999999), activity_type (web_security), and note (HTML, PHP). A 'View source' button is visible next to the parameters list.

Name	Value
fullname	Bob Green
email	alice@kku.ac.th
student_id	673330000-1
phone	0899999999
activity_type	web_security
note	HTML, PHP





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



method="post"

Registration Result

Request Method: **POST**

Registration data has been received successfully.

Full Name	Alice Green
Email	alice@kku.ac.th
Student ID	673330000-1
Phone	0899999999
Activity Type	Web Security
Note	HTML, PHP

[Back to Form](#)



The screenshot shows the Network tab of a web browser. A request to 'process.php' is selected. The 'Payload' tab is active, showing the form data sent in the POST request:

Name	Value
fullname	Alice Green
email	alice@kku.ac.th
student_id	673330000-1
phone	0899999999
activity_type	web_security
note	HTML, PHP





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



method="post"

ไม่กรอกข้อมูล Full Name ปกติจะขึ้นแจ้งเตือน ไม่สามารถกด Register ส่งค่าไปหน้า process.php ได้

Student Registration

Full Name

Email

 Please fill out this field.

Student ID

Phone

Activity Type

Web Security

Note

HTML, PHP

Register

Reset





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ใช้ method="post"

แต่สามารถแก้ไขคำสั่ง HTML ได้ โดยเปิด Dev Tool แล้ว ไปที่แท็บ Element แล้วคลิกขวา เลือก Edit as HTML จะสามารถลบ required ออกได้

The screenshot shows the Chrome DevTools 'Elements' panel. The DOM tree on the left shows a form with an input field selected. A right-click context menu is open, displaying options: 'Add attribute', 'Edit attribute', 'Edit as HTML' (highlighted), 'Duplicate element', 'Delete element', 'Cut', and 'Copy'. The HTML structure visible is:

```
<!DOCTYPE html>
<html lang="en">
  <head>
  </head>
  <body>
    <div class="container">
      <h1>Student Registration</h1>
      <form action="process.php" method="post">
        <label for="fullname">Full Name</label>
        <input type="text" id="fullname" name="fullname" placeholder="Enter your full name" />
        <label for="email">Email</label>
```

The screenshot shows the raw HTML source code of the page. The input field's attributes are clearly visible:

```
<input type="text" id="fullname" name="fullname" maxlength="50" placeholder="Enter your full name" />
```





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ใช้ method="post"

หากลบ required ในส่วนของ Browser ออกแล้ว จะไม่สามารถตรวจสอบค่าว่างได้ และสามารถกดปุ่ม Register ไปหน้าถัดไปได้ แต่ไฟล์ process.php ยังมีการตรวจสอบอยู่ในส่วนของ Server ดังนั้น ต้องตรวจสอบค่าว่างและเงื่อนไขของข้อมูลที่ Server ทุกครั้ง

Student Registration

Full Name

Email

Student ID

Phone

Activity Type

Note

Register

Reset

Registration Result

Request Method: **POST**

Please correct the following errors:

- Full Name is required.

Back to Form





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ใช้ method="post"

หากไม่ได้มีการใช้ htmlspecialchars() หรือ h() ใน input ของ Full Name มีผู้ไม่หวังดีกรอก คำสั่ง HTML/Script เช่น `<h1>Hello</h1>` หรือ `<script>alert(1)</script>`

ไฟล์บางส่วนของ process.php

ตัวอย่าง เมื่อกรอก `<h1>Hello</h1>` ในช่วง Full Name

```
<table>
  <tr>
    <th>Full Name</th>
    <td><?php echo $fullname; ?></td>
  </tr>
  <tr>
    <th>Email</th>
    <td><?php echo h($email); ?></td>
  </tr>
  <tr>
    <th>Student ID</th>
    <td><?php echo h($student_id); ?></td>
  </tr>
```

Student Registration

Full Name

`<h1>Hello</h1>`

Email

alice@kku.ac.th

Student ID

673330000-1

Phone

0899999999

Activity Type

Web Security

Note

HTML, PHP

Register

Reset

Registration Result

Request Method: POST

Registration data has been received successfully.

Full Name

Hello

Email

alice@kku.ac.th

Student ID

673330000-1

Phone

0899999999

Activity Type

Web Security

Note

HTML, PHP

Back to Form





ตัวอย่างตรวจสอบข้อมูล input ด้วย PHP(ต่อ)



ใช้ method="post"

ตัวอย่างการกรอก `<script>alert("I am a script.")</script>` ในช่วง Full Name

Student Registration

Full Name

Email

Student ID

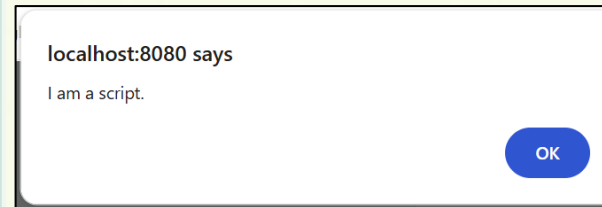
Phone

Activity Type

Web Security

Note

RegisterReset



Registration Result

Request Method: **POST**

Registration data has been received successfully.

Full Name	
Email	alice@kku.ac.th
Student ID	673330000-1
Phone	0899999999
Activity Type	Web Security
Note	HTML, PHP

Back to Form

ดังนั้น ต้องใช้ `htmlspecialchars()` ก่อนแสดงผลข้อมูลจากผู้ใช้





อ้างอิง



- W3Schools PHP Tutorial — PHP Syntax, Variables, Echo/Print, Data Types, Operators, Conditions, Loops, Functions, Arrays, Superglobals, RegEx
- W3Schools PHP Forms — `$_GET`, `$_POST`
- • PHP Manual — `htmlspecialchars()`, superglobals, filter functions

